Безопасность RTK CRM

Документ описывает реализованные меры защиты и соответствие требованиям 152-ФЗ, приказа ФСТЭК России № 117 и 149-ФЗ. Подробные результаты статического анализа и проверки зависимостей — в `security/SAST-SCA.md`.

Реализованные меры

- JWT Bearer-аутентификация с ограниченным временем жизни токена.
- RBAC: `user`, `manager`, `admin`; изменение справочников и workflow ограничено ролями.
- Пароли хранятся только как bcrypt-хеши.
- Запросы к базе выполняются через SQLAlchemy ORM.
- Изменяющие запросы фиксируются в `action_logs`; чувствительные поля (`password`, `token`, `secret`) редактируются перед записью.
- CORS использует явный список origin, без wildcard при credentials.
- Экспорт и файлы доступны только авторизованным пользователям.
- Загрузка файлов ограничена расширениями, MIME-типами и размером 50 МБ.
- Ограничение попыток входа: 5 неуспешных за 60 секунд с одного IP → `429`.
- Заголовки безопасности на всех ответах: `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy`, а в production — `Strict-Transport-Security`. Для API дополнительно `Content-Security-Policy: default-src 'none'; frame-ancestors 'none'`; `/docs` и `/redoc` из CSP исключены, потому что Swagger UI использует инлайновые скрипты.

152-ФЗ «О персональных данных»

Требование	Реализация
Правовое основание и согласие	Баннер cookie-согласия (`rtk_cookie_consent` в `localStorage`); обязательные и аналитические категории разделены
Минимизация данных	Хранятся рабочие данные пользователей (ФИО, email, роль) и контактных лиц вузов (ФИО, телефон, email)
Локализация БД	Целевой контур — Yandex Cloud (данные в РФ). Публичный демонстрационный стенд на внешнем хостинге для реальных ПДн не предназначен
Обезличивание	Экспорт и выгрузки содержат только рабочие идентификаторы и не раскрывают учётные данные; аудит-лог редактирует секреты
Сроки хранения	Определяются эксплуатантом; технически аудит-лог и `action_logs` поддерживают выборочную выгрузку и очистку
Ответственный за обработку	Назначается организацией-эксплуатантом

Обрабатываются рабочие данные пользователей и контактных лиц вузов. В промышленной эксплуатации необходимо разместить базу и backend в российском контуре (Yandex Cloud), ограничить доступ к персональным данным, определить сроки хранения и назначить ответственного за обработку. Публичный демонстрационный стенд на внешнем хостинге не следует использовать для реальных персональных данных без отдельной оценки и миграции.

Cookie-согласие хранится в `localStorage` под ключом `rtk_cookie_consent`; аналитические и маркетинговые категории по умолчанию отключены. Подробный план миграции в Yandex Cloud находится в `infra/yandex-cloud/README.md`.

Данные от кейсодержателя

Кейсодержатель передал три файла с примерами выгрузок: `Вендоры.xlsx` (каталог ИТ-продуктов с контактами), `Данные оплат.json` (заявки B2C) и `Загрузка пользователей.xlsx` (анкета физлица).

`Загрузка пользователей.xlsx` — потенциально чувствительный файл: помимо ФИО, телефона и email он содержит колонки СНИЛС, серии и номера паспорта, адреса регистрации и данные диплома. **В переданном экземпляре эти колонки пусты** — заполнены только ФИО, телефон и email, то есть фактических персональных данных повышенной чувствительности файл не содержит.

Тем не менее исходные выгрузки как есть в репозиторий не попадают: любые таблицы со ПДн исключены правилами `.gitignore` (`*.xlsx`, `*.xls`, `Вендоры*`, `Данные оплат*`, `Загрузка пользователей*`). Причины:

- анкета спроектирована под сбор СНИЛС и паспортных данных, и любой заполненный экземпляр нельзя коммитить;
- прототип не предназначен для хранения реальных паспортных данных — поля повышенной чувствительности в модели данных не реализованы;
- тестовые фикстуры для импорта собираются в памяти (`tests/test_excel_import.py`), поэтому исходные таблицы в репозитории не нужны.

Вместо исходных файлов в репозиторий положены **обезличенные образцы** тех же форматов (раздел «Обезличивание данных» ниже) — их достаточно для демонстрации импорта, и они не содержат ПДн.

В демо-данные (`backend/seed.py`) из этих файлов попадают только обезличенные сведения: справочник вендоров и продукты, а также заявки B2C без контактных данных. Телефоны и адреса почты заменены на синтетические значения в домене `example.ru`; реальные ФИО контактных лиц не сохраняются.

Обезличивание данных

Образцы форматов выгрузок, нужные для демонстрации импорта, всё же добавлены в репозиторий — в обезличенном виде, каталог `docs/examples/` (зеркало — `frontend/public/docs/examples/`) и с латинскими именами, чтобы файлы корректно отдавались статикой на Linux:

Файл	Что обезличено
`vendors.xlsx`	Контакты вендоров — синтетические (`example.ru`)
`payments_b2c.json`	ФИО/телефон заявителей — тестовые
`users_b2c.xlsx`	ПДн-колонки заменены заглушками

В `users_b2c.xlsx` обезличены все поля персональных данных:

Поле	Значение
СНИЛС	`000-000-000 00`
Серия и номер паспорта	`0000, 000000`
Кем выдан паспорт	`ОТДЕЛОМ УФМС РОССИИ`
Дата выдачи паспорта	`01.01.2020`
Код подразделения	`000-000`
Адрес регистрации	`г. Москва, ул. Примерная, д. 1, кв. 1`
Индекс регистрации	`000000`

ФИО, телефон и email оставлены тестовыми — это вымышленные данные, не относящиеся к реальным лицам.

Пересборка обезличенной копии из оригинала: `python scripts/anonymize_case_data.py <путь к «Загрузка пользователей.xlsx»>`. Оригинал хранится вне репозитория.

Правила `.gitignore` по-прежнему исключают все выгрузки с ПДн (`*.xlsx`, `*.xls`, `Вендоры*`, `Данные оплат*`, `Загрузка пользователей*`); исключение сделано точечно только для обезличенных образцов в `docs/examples/`.

Проверено: `git log --all --full-history -- "*Загрузка*"` — пусто. История репозитория не содержит реальных ПДн. Подробности — в `docs/examples/README.md`.

Приказ ФСТЭК России № 117

Мера	Реализация
Идентификация и аутентификация	JWT с bcrypt-хешами паролей; ограничение попыток входа
Управление доступом (RBAC)	Роли `user`/`manager`/`admin`, проверка через FastAPI-зависимости на каждом эндпоинте
Регистрация событий безопасности	Middleware `audit_middleware` → `action_logs`: пользователь, действие, сущность, IP, время
Антивирусная защита	На уровне инфраструктуры (документы к загрузке не исполняются; файлы отдаются как вложения)
Целостность	Ограничения БД, внешние ключи, миграции Alembic; уникальность этапов workflow
Доступ к журналам	Просмотр аудит-лога и выгрузка CSV ограничены ролью администратора
Шифрование канала	HTTPS/TLS на reverse proxy (Nginx); HSTS в проде
Резервное копирование	Ежедневный `pg_dump` в `infra/yandex-cloud/backup.sh`

149-ФЗ «Об информации…»

Регулирует оборот информации в системе: аудит-лог обеспечивает прослеживаемость изменений, ролевая модель — разграничение доступа к информационным ресурсам, а выгрузка данных — контролируемый формат (CSV/JSON/XLSX). Интеграция с внешними LMS/CMS выполняется по HTTPS с явными ключами доступа.

Секреты и эксплуатация

`SECRET_KEY`, `DATABASE_URL` и другие секреты передаются только через переменные окружения. В production приложение отклоняет дефолтный или слишком короткий `SECRET_KEY`. Файлы `.env` не должны попадать в Git.

GigaChat

Сводка по карточке — единственное обращение к внешнему ИИ-сервису, поэтому у него отдельные требования.

- Ключ авторизации (`GIGACHAT_CREDENTIALS`) хранится только в переменных окружения и в `.env` на сервере. В репозиторий он не попадает, в логах не печатается, в ответах API не возвращается.
- Ключ ротируется в личном кабинете GigaChat Developers. Компрометация ключа не даёт доступа к данным CRM: ключ используется только для запроса сводки.
- TLS-соединение проверяется по корневому сертификату НУЦ Минцифры. Он публичный, поставляется в `backend/certs/` и вшивается в образ. Отключение проверки (`GIGACHAT_VERIFY_SSL=false`) не применяется в рабочем контуре.
- В промпт уходят только названия (вуз, продукт, этап), тексты комментариев и служебные поля. Персональные данные (СНИЛС, паспорт, адрес, телефон) в карточке не хранятся — они отбрасываются на этапе импорта, поэтому в GigaChat не попадают.
- Доступ проверяется до сборки промпта: КАМ не может получить сводку по чужому взаимодействию, данные чужой карточки во внешний сервис не уходят.
- Сервис работает в закрытом контуре Сбера и соответствует требованиям 152-ФЗ: персональные данные не передаются, обработка идёт в РФ.

Подробности: `AI.md`.

Аутентификация: JWT и Keycloak

В ТЗ Keycloak указан как вариант авторизации. Реализованы оба режима, переключаемые переменной `AUTH_MODE`:

`AUTH_MODE=jwt` (по умолчанию). Локальный контур для прототипа и демонстрации:

- `python-jose` подписывает Bearer-токены (HS256, ключ `SECRET_KEY`);
- `passlib` использует bcrypt для паролей;
- RBAC выполняется FastAPI-зависимостями;
- аудит сохраняет изменяющие операции без секретных полей.

`AUTH_MODE=keycloak`. Корпоративный SSO для закрытого контура:

- подпись токена проверяется по публичным ключам realm (RS256, JWKS);
- ключи кэшируются на 300 секунд, ротация обрабатывается по неизвестному `kid`;
- проверяются `iss`, `aud` и `exp`;
- роли берутся из токена (`realm_access` и `resource_access`), поэтому смена роли в Keycloak действует сразу;
- пользователь из Keycloak без учётки в CRM создаётся автоматически с ролью по приоритету admin > manager > kam; локальный вход паролем для него закрыт.

В обоих режимах возвращается локальная запись `User`: она нужна для связей в БД и RBAC, поэтому бизнес-логика не зависит от способа аутентификации.

Если Keycloak недоступен, API отвечает `503`, а не `401`: токен может быть корректным, и клиент не должен разлогиниваться из-за сетевой ошибки.

Подробности: `KEYCLOAK.md`.

Переменная `MOCK_MODE=true` фиксирует текущий режим JWT + БД. Автоматического переключения на Keycloak при `MOCK_MODE=false` нет — режим задаётся явно через `AUTH_MODE`, чтобы не включить SSO случайно при смене флага демо-данных.